

OWASP ZAP

DAST e análise de segurança de aplicações Web em ambientes autorizados.

O que é OWASP ZAP

ZAP é um proxy de segurança open source que permite observar e manipular tráfego HTTP/HTTPS e apoiar testes dinâmicos de aplicações Web.

Passive Scan

O Passive Scan analisa mensagens que passam pelo proxy sem enviar ataques adicionais. É uma boa porta de entrada para observar headers, cookies e possíveis problemas enquanto o QA navega pela aplicação.

Active Scan

O Active Scan envia requisições de ataque para procurar vulnerabilidades. Use somente em sistemas e ambientes para os quais exista autorização explícita.

Quick Start e proxy

O Quick Start pode spider/scanear uma URL e também iniciar navegadores pré-configurados para usar o proxy do ZAP. Em cenários avançados, configure o browser ou testes automatizados para trafegar pelo proxy.

QA e DAST no pipeline

ZAP pode participar de pipelines em ambientes controlados. Defina escopo, autenticação, contexto e critérios de triagem; findings automáticos precisam de análise para separar risco real de falso positivo.

Ponto de atenção

Nunca execute Active Scan em sistemas sem autorização. Scanners podem alterar estado, criar dados e gerar carga significativa. Preserve evidências e trate credenciais/certificados com cuidado.